

VPN - Virtual Private Network

VPN ist ein logisches privates Netzwerk auf einer öffentlich zugänglichen Infrastruktur. Nur die Kommunikationspartner, die zu diesem privaten Netzwerk gehören, können miteinander kommunizieren und Informationen und Daten austauschen.

Eine allgemein gültige Definition für VPN gibt es allerdings nicht. Der Begriff und die Abkürzung VPN stehen für eine Vielzahl unterschiedlicher Techniken. So werden VPN-Verbindungen oft als sicher angesehen, obwohl Aspekte wie Verschlüsselung oder Authentifizierung in manchen Protokollen, Produkten und Lösungen keine Rolle spielen.

Damit VPN-Verbindungen sicher sind müssen Authentizität, Vertraulichkeit und Integrität sichergestellt sein. Authentizität bedeutet die Identifizierung von autorisierten Nutzern und die Überprüfung der Daten, dass sie nur aus der autorisierten Quelle stammen. Vertraulichkeit und Geheimhaltung wird durch Verschlüsselung der Daten hergestellt. Mit der Integrität wird sichergestellt, dass die Daten von Dritten nicht verändert wurden.

VPN-Typen und unterschiedliche Bezeichnungen

- End-to-Site-VPN
 - Host-to-LAN-VPN
 - Host-to-Gateway-VPN
 - Remote-Access-VPN
 - Road-Warrior-Szenario
- Site-to-Site-VPN
 - LAN-to-LAN-VPN
 - Gateway-to-Gateway-VPN
 - Branch-Office-VPN
- End-to-End-VPN
 - Host-to-Host-VPN
 - Remote-Desktop-VPN

End-to-Site-VPN / Remote-Access-VPN

End-to-Site-VPN beschreibt ein VPN-Szenario, bei dem Heimarbeitsplätze oder mobile Benutzer (Außendienst) in ein Unternehmensnetzwerk eingebunden werden. Der externe Mitarbeiter soll so arbeiten, wie wenn er sich im Netzwerk des Unternehmens befindet. Man bezeichnet dieses VPN-Szenario auch als Remote-Access-VPN oder spricht vom Road-Warrior-Szenario.

Die VPN-Technik stellt eine logische Verbindung, den VPN-Tunnel, zum entfernten lokalen Netzwerk über ein öffentliches Netzwerk her. Hierbei muss ein VPN-Client auf dem Computer des externen Mitarbeiters installiert sein.

Im Vordergrund steht ein möglichst geringer, technischer und finanzieller Aufwand für einen sicheren Zugriff auf das entfernte Netzwerk.

Site-to-Site-VPN / LAN-to-LAN-VPN / Branch-Office-VPN

Site-to-Site-VPN und LAN-to-LAN-VPN, oder auch Branch-Office-VPN genannt, sind VPN-Szenarien, um mehrere lokale Netzwerke von Außenstellen oder Niederlassungen (Filialen) zu einem virtuellen Netzwerk über ein öffentliches Netz zusammenzuschalten. Netzwerke, die sich an verschiedenen Orten befinden, lassen sich über eine angemietete Standleitung direkt verbinden. Diese Standleitung entspricht in der Regel einer physikalischen Festverbindung zwischen den beiden Standorten.

Da jedes Netzwerk in der Regel auch eine Verbindung zum Internet hat, bietet es sich an, diese Internet-Verbindung zur Zusammenschaltung von zwei oder mehr Netzwerken mit VPN-Technik (LAN-to-LAN-Kopplung) zu nutzen. Bei VPNs über das Internet entstehen einmalige Kosten für die Einrichtung und laufende Kosten nur die, die für den Internet Service Provider zu bezahlen sind.

Virtuelle private Netze (VPN) werden immer öfter über das Internet aufgebaut. Das Internet wird so zur Konkurrenz zu den klassischen WAN-Diensten der Netzbetreiber. VPNs lassen sich über das Internet billiger und flexibler betreiben.

Eine Variante von Site-to-Site-VPN ist das Extranet-VPN. Während ein Branch-Office-VPN nur mehrere lokale Netzwerke einer Firma verbindet, ist ein Extranet-VPN ein virtuelles Netzwerk, das die Netzwerke unterschiedlicher Firmen miteinander verbindet. In der Regel geht es darum bestimmte Dienste fremder Unternehmen ins eigene Netzwerk zu integrieren oder Dienste für fremde Unternehmen anzubieten. Zum Beispiel für Geschäftspartner, Lieferanten und Support-leistende Unternehmen. Dabei gewährt man dem externen Unternehmen Zugriff auf Teilbereiche des eigenen Netzwerks. Die

Zugriffsbeschränkung erfolgt mittels einer Firewall zwischen dem lokalen Netzwerk und dem Dienste Netzwerk. Extranet-VPNs ermöglichen eine sichere Kommunikation bzw. einen sicheren Datenaustausch zwischen den beteiligten Unternehmen.

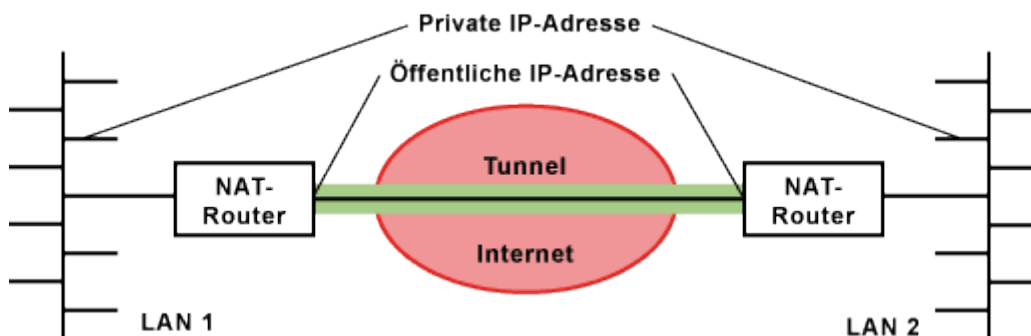
End-to-End-VPN / Host-to-Host-VPN / Remote-Desktop-VPN



End-to-End-VPN beschreibt ein VPN-Szenario, bei dem ein Client auf einen anderen Client in einem entfernten Netzwerk zugreift. Hierbei deckt der VPN-Tunnel die gesamte Verbindung zwischen zwei Hosts ab. Auf beiden Seiten muss eine entsprechende VPN-Software installiert und konfiguriert sein. In der Regel ist der Verbindungsaufbau nur durch die Unterstützung einer zwischengeschalteten Station möglich. Das bedeutet, eine direkter Verbindungsaufbau von Host zu Host ist nicht möglich. Stattdessen bauen beide Seiten eine Verbindung zu einem Gateway auf, dass die beiden Verbindungen dann zusammenschaltet.

Typische Anwendung eines End-to-End-VPN ist Remote-Desktop über öffentliche Netze. Während RDP und VNC sich wegen der fehlenden Verschlüsselung nur für den Einsatz in lokalen Netzwerken eignet, gibt es für Remote-Desktop-VPNs meist nur proprietäre und kommerzielle Lösungen. Zum Beispiel Teamviewer, GotoMyPC und Anydesk.

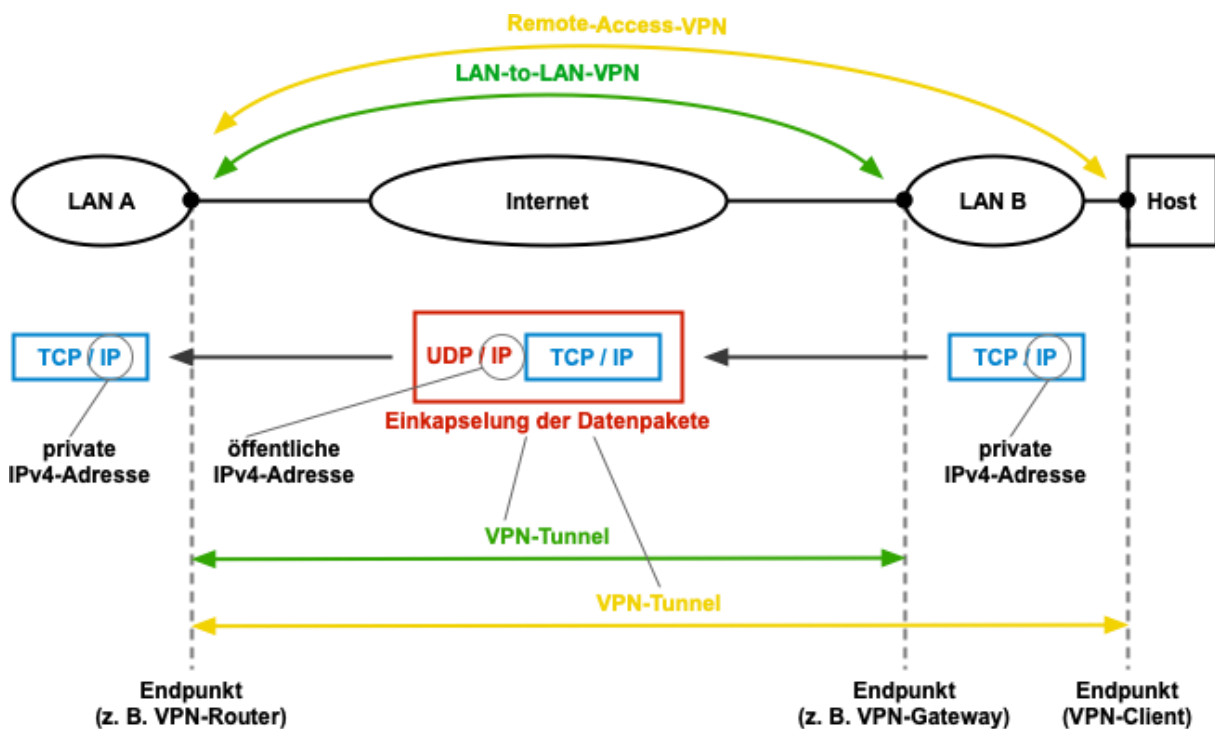
VPN-Tunnel und VPN-Endpunkt



Um eine gesicherte Datenübertragung über das unsichere Internet zu gewährleisten, wird mit einem Tunneling-Protokoll eine verschlüsselte Verbindung, der VPN-Tunnel, aufgebaut. Der Tunnel ist eine logische Verbindung zwischen beliebigen Endpunkten. Meist sind das VPN-Clients, VPN-Server oder VPN-Gateways. Man nennt diese virtuellen Verbindungen Tunnel, weil die Nutzdaten in einer virtuellen Verbindung getunnelt werden.

Ein VPN-Endpunkt ist die Stelle, an der der VPN-Tunnel endet bzw. beginnt. Der Endpunkt ist der Host, der für die Einhaltung von Authentizität, Vertraulichkeit und Integrität zuständig ist. Ein VPN-Endpunkt kann ein Router, Gateway oder auch ein Software-Client sein.

VPN-Tunnel / VPN-Endpunkt



Was ist der VPN-Tunnel?

Der VPN-Tunnel ist eine logische Verbindung zwischen beliebigen Endpunkten. Meist sind das VPN-Clients, VPN-Server und VPN-Gateways. Man nennt diese virtuellen Verbindungen Tunnel, weil der eigentliche Inhalt der Datenpakete für andere nicht sichtbar ist.

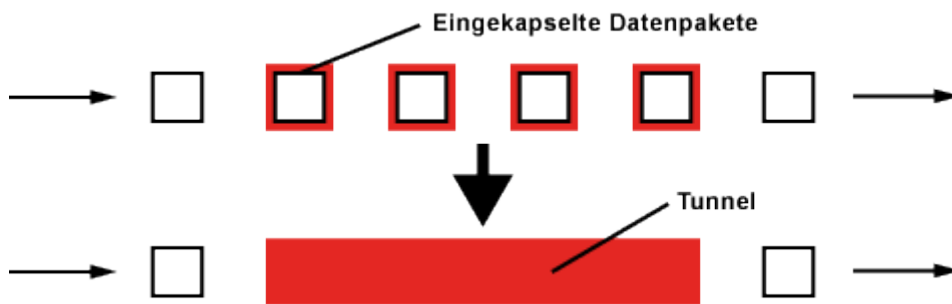
Was ist ein VPN-Endpunkt?

Ein VPN-Endpunkt ist die Stelle, an der der VPN-Tunnel endet bzw. beginnt. Der Endpunkt ist der Host, der für die Einhaltung von Authentizität, Vertraulichkeit und Integrität zuständig ist. Ein VPN-Endpunkt kann ein Router, Gateway oder auch ein Software-Client sein.

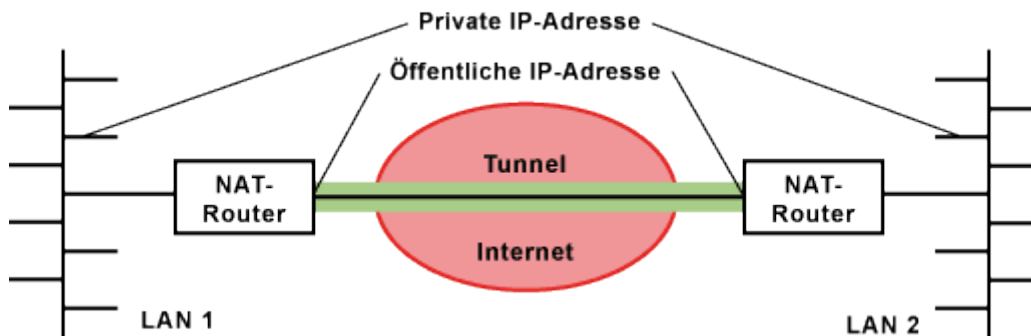
Der VPN-Endpunkt auf einem PC oder Notebook in Form eines Software-Clients erzeugt im Prinzip einen virtuellen Netzwerk-Adapter. Der Datenverkehr für das VPN wird in diesen virtuellen Adapter umleitet.

Was ist ein VPN?

Ein VPN ist ein logisches privates Netzwerk auf einer öffentlich zugänglichen Infrastruktur. Meist spricht man von VPN-Verbindungen zwischen Netzwerken oder zwischen einem Netzwerk und Clients in einem anderen Netzwerk.

Tunneling

Das Internet hat den Nachteil, dass die Infrastruktur im Detail nicht bekannt ist und der Weg zwischen zwei Kommunikationspartnern nicht nachvollziehbar, vorhersagbar und kontrollierbar ist. So kann an jedem Knoten ein Datenpaket gespeichert, verändert oder gelöscht werden. Die Daten werden also ungesichert über das Internet übertragen. Tunneling erlaubt es, Pakete eines Netzwerkprotokolls in die Pakete eines anderen Netzwerkprotokolls einzukapseln und dabei auch zu verschlüsseln.



Um eine gesicherte Datenübertragung über das unsichere Internet zu gewährleisten, wird mit einem Tunneling-Protokoll eine verschlüsselte Verbindung, der VPN-Tunnel, zwischen den Endpunkten aufgebaut. Das technische Prinzip einer VPN-Verbindung ist dabei in der Regel immer gleich. Am Startpunkt des Tunnels werden die Pakete eingekapselt. Am Endpunkt werden die Pakete wieder entkapselt. Dabei kann jedes Datenpaket verschlüsselt werden. Der Inhalt des ursprünglichen Pakets können andere nicht sehen.

Eine andere sinnvolle Anwendung, ist das Verstecken von privaten Netzwerkadressen, in dem man IP-Pakete in IP-Paketen tunnelt. Auf diese Weise werden Netzwerke über das Internet miteinander verbunden. Die IP-Pakete mit privaten Adressen werden in IP-Pakete mit der öffentlichen Adresse verpackt.

Tunneling im OSI-Schichtenmodell

Für das Tunneling gibt es zwei Ansätze. Im ersten Ansatz wird auf der Schicht 3 des OSI-Schichtenmodells das Tunneling aufgebaut. Dabei wird zur Adressierung der Schicht bzw. der Datenpakete das Internet Protocol (IP) verwendet. Man spricht dann vom IP-in-IP-Tunneling. In der Regel wird IPsec für diese Lösung verwendet.

Ein anderer Ansatz greift direkt auf der Schicht 2 des OSI-Schichtenmodells ein. Hier

wird das Datenpaket der Schicht 3 verschlüsselt und dann mit der physikalischen Adresse adressiert. In der Regel werden PPTP oder L2TP für diese Lösung verwendet.

Standardisierte Tunneling-Protokolle (VPN)

- [PPTP - Point-to-Point Tunneling Protocol](#) (veraltet)
- L2F - Layer 2 Forwarding (Cisco)

PPTP und L2F sind keine echten Standards. Sie haben nur einen informellen Status.

- [L2TP - Layer-2-Tunneling-Protocol](#) (Microsoft-Umgebungen)
- [IPsec](#) (im Tunnelmodus)
- [MPLS - Multi-Protocol Label Switching](#)
- [Layer-2-VPN](#)

MPLS ist eigentlich kein Tunneling-Protokoll. Allerdings kann man damit Layer-2-VPNs aufbauen. Allerdings nur Netzbetreiber.

IPsec als Tunneling-Protokoll zu bezeichnen ist falsch. Es ist im allgemeinen Sinne ein Sicherheitsprotokoll, das auch Tunneling beherrscht und im Regelfall auch dafür eingesetzt wird.

- VPN-Protokolle und VPN-Lösungen

Proprietäre VPN-Tunneling-Protokolle

- Altavista Tunnel
- Bay Dail VPN Service (Bay-DVS)
- Ascend Tunnel Management Protocol (ATMP)

L2F - Layer 2 Forwarding

L2F ist mit L2TP verwandt und wurde von Cisco als Software-Modul für RAC (Remote Access Concentrator) und Router entwickelt. Es handelt sich dabei nicht um eine Client-Implementierung, wie zum Beispiel bei PPTP oder L2TP. Der Benutzer kommt mit L2F nicht in Berührung.

L2F bietet keine Verschlüsselung und auch keine starke Authentisierung. L2F kann lediglich verschiedene Netzwerkprotokolle tunneln. Zwei L2TP-Server dienen als Endpunkt für einen L2F-Tunnel.

Vergleich: VPN-Tunneling-Protokolle

VPN-Protokoll	IPsec	L2TP	PPTP	MPLS
OSI-Schicht	Schicht 3	Schicht 2	Schicht 2	Schicht 2
Standard	Ja	Ja	Nein	Ja
Paketauthentisierung	Ja	Nein	Nein	Nein
Benutzerauthentisierung	Ja	Ja	Ja	Nein
Datenverschlüsselung	Ja	Nein	Ja	Nein
Schlüsselmanagement	Ja	Nein	Nein	Nein
Quality of Service	Ja	Nein	Nein	Ja
IP-Tunneling	Ja	Ja	Ja	Ja
IPX-Tunneling	Nein	Ja	Ja	Ja
Hauptanwendung	End-to-End	Provider	End-to-End	Netzbetreiber

Die Angabe Ja und Nein sind nicht als Wertungen, sondern Eigenschaften zu verstehen. In Abhängigkeit bestimmter Eigenschaften eignet sich ein bestimmtes Tunneling-Protokoll für die eine oder andere Anwendung besser oder schlechter.

VPN-Endpunkt: VPN-Router / VPN-Gateway / VPN-Server

VPN-Lösungen gibt es als Hardware (VPN-Router), Software (VPN-Server) oder auch als Service (Layer-2-VPN vom Netzbetreiber). Typischerweise setzt man an VPN-Endpunkten einen VPN-Router oder ein VPN-Gateway ein. Es gibt aber auch Server, auf denen VPN-Dienste oder VPN-Software installiert sind. Diese VPN-Server dienen dann als VPN-Endpunkte. Ein eigenständiger VPN-Server ist eher selten nötig. VPN-Gateway-Funktionen finden sich auch in Routern und Firewalls.

VPN-Gateways und -Router können VPN-Verbindungen und normale Verbindungen verarbeiten. Die VPN-Verbindungen erkennen sie am Header der Datenpakete oder an der IP-Protokollnummer.

Eine Sonderform sind VPN-Services von Netzbetreibern, die keine Installation zusätzlicher Hardware notwendig macht.

VPN-Protokolle und VPN-Lösungen

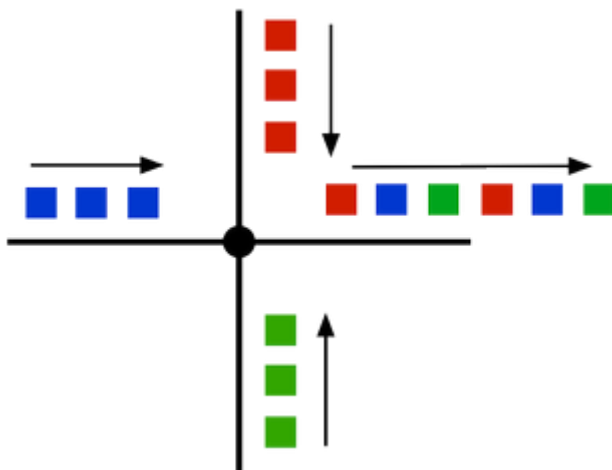
Ein Protokoll legt fest, wie zwei Teilnehmer einer Verbindung miteinander kommunizieren. Bei VPN-Protokollen gibt es zusätzlich noch Methoden zur Verschlüsselung der Verbindung und gegenseitiger Authentifizierung der Teilnehmer.

Die meisten VPN-Protokolle sind in eine VPN-Lösung eingebettet. Das heißt, in Kombination mit Hardware und Software zu nutzen. Wie genau die Lösung aussieht hängt vom Hersteller ab. Parallel dazu gibt es Open-Source-Software, die sich flexibel zu einer VPN-Lösung arrangieren lässt.

Layer-2-VPN

Bei einem Layer-2-VPN wird das VPN von einem Netzbetreiber bereitgestellt. Der Netzbetreiber überträgt die Daten über sein nicht-öffentliches Netz und dessen Verbindungen. Früher waren das üblicherweise Frame Relay, X.25 und ATM. Heute ist das MPLS.

MPLS - Multi-Protocol Label Switching



MPLS bildet eine Brücke zwischen verbindungsorientierten Übertragungstechniken und verbindungslosen, paketbasierten Verfahren. Mit MPLS ist es möglich, verschiedene Arten von Daten, wie zum Beispiel Telefonie oder Internet-Verkehr, über die gleiche Infrastruktur zu transportieren. Obwohl im Hintergrund paketorientierte Übertragungstechniken arbeiten, sieht das Netz für den Kunden wie eine Standleitung aus. Auf diese Weise kann der Kunde verschiedene Arten von Paketen durch das MPLS-Netz schicken. Manchmal weiß der Kunde gar nicht, dass es sich um ein MPLS-Netz handelt. Er mietet schlicht und einfach eine Standleitung zur Übertragung von Ethernet-, ATM-, Frame-Relay-, oder IP-Paketen.

Obwohl man bei einem VPN-Daten verschlüsselt, ist das bei einem Layer-2-VPN nicht der Fall. Der Netzbetreiber verschlüsselt keine Daten. Das ist auch nicht nötig. Fremde

haben keinen Zugriff auf die Infrastruktur des Netzbetreibers. Und die Nutzer (Kunden des Netzbetreibers) kommen mit den unverschlüsselten Daten anderer Nutzer nicht in Berührung. Denn die Übertragungstechniken des Netzbetreibers halten die verschiedenen Datenströme getrennt. Das Risiko vor unberechtigtem Zugriff ist relativ gering.

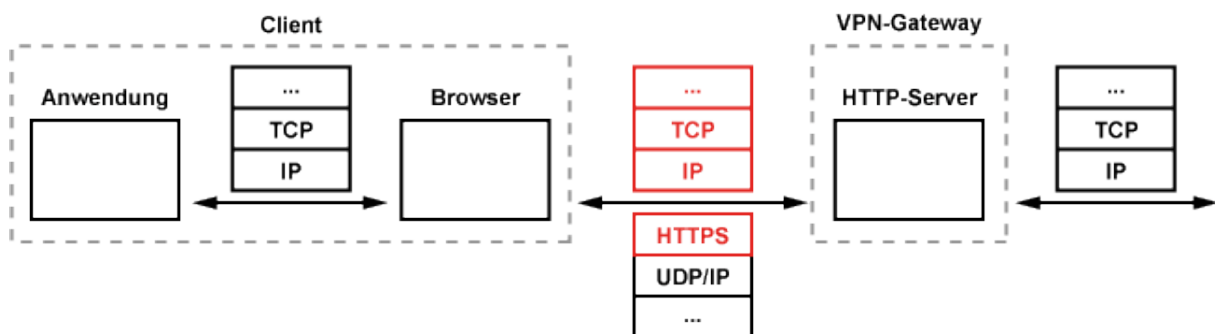
MPLS ist nur bei der Kopplung großer Netze sinnvoll. Und auch nur dann, wenn man die Netze nicht übers öffentliche Internet, sondern über das private Netz eines Netzbetreibers verbinden will. Zum Beispiel, weil einem der Betrieb eines eigenen VPN zu unsicher ist oder eine bestimmte Bandbreite gefordert wird.

Hinweis: Die Nutzung eines Netzbetreiber-VPN setzt voraus, dass die VPN-Endpunkte am Netz des Netzbetreibers angeschlossen sind. Die VPN-Endpunkte müssen zwingend am gleichen Zugangsnetz hängen.

SSL-VPN

SSL-VPN ist eine Art Remote-Access-VPN, das eine Alternative zu IPsec darstellt. Während die meisten VPN-Techniken relativ komplex und fehleranfällig sein können, kommt SSL-VPN durch jede Firewall und durch jedes Netzwerk hindurch. Weil SSL-VPN auf die Standards SSL bzw. TLS baut, hat sich daraus der Begriff SSL-VPN gebildet. SSL bzw. SSL-VPN beherrscht kein Tunneling und eignet sich deshalb ausschließlich für Remote-Access- oder Extranet-Anwendungen. Um Standorte zu vernetzen ist SSL-VPN eher ungeeignet. Es wäre sehr umständlich einzurichten.

Funktionsweise von SSL-VPN



Bei einem SSL-VPN ist in der Regel ein Browser der VPN-Client, der auf dem Client-Rechner läuft. Dabei werden die Daten mittels HTTPS vom Browser zu einem HTTP-Server (Webserver), der als VPN-Gateway dient, übertragen. HTTPS ist in jedem Browser eingebaut und funktioniert praktisch überall. Auch durch eine Firewall oder einen NAT-Router hindurch.

Um auch Daten von außerhalb des Browsers übertragen zu können, wird innerhalb des Browsers ein Plugin, Java-Applet oder eine ActiveX-Komponente ausgeführt, die als Gateway dient und die die Daten über die verschlüsselte Verbindung umleitet.

Browser-based

Ein typisches SSL-VPN ist ein Browser-basiertes SSL-VPN. Alles was man braucht ist ein Browser, der SSL/TLS beherrscht und einen Webserver mit der dazu passenden Implementierung. Die Verbindung wird dabei über HTTPS-Requests und -Responses zwischen Browser und Server abgewickelt. Im Gegensatz zu HTTP ist die Verbindung bei HTTPS verschlüsselt.

Allerdings hat diese Art von VPN keine Vorteile. Es können keine Dienste außerhalb des Browsers, wie E-Mail oder File-Server benutzt werden. Es bräuchte dazu ein Web-Frontend, wie zum Beispiel ein Webmailer, der im Browser ausgeführt wird.

Im Prinzip handelt es sich beim Zugriff auf einen Webmail-Dienst, wie er von verschiedenen Internet-Service-Providern angeboten wird ein Browser-based SSL-VPN.

Client-based

Es gibt VPN-Clients, die auch SSL-VPN beherrschen. Häufig als Backup-Lösung, wenn keine Verbindung mit IPsec oder anderen VPN-Protokollen möglich ist. Beispielsweise weil eine Firewall den Verbindungsaufbau blockiert.

Nach einem erfolgreichen Verbindungsaufbau mit SSL-VPN klingt sich der VPN-Client wie üblich als zusätzliche Netzwerkschnittstelle ins Betriebssystem ein.

Enhanced Browser-based

Bei Client-basierten SSL-VPNs muss man auf alle Fälle einen Client installieren, wobei die Vorteile eines Client-losen VPNs nicht mehr gegeben sind. Im Vergleich ist mit einem rein Browser-basierte SSL-VPN vieles nicht möglich. Deshalb kombiniert man Client-basiertes und Browser-basiertes SSL-VPN miteinander.

Dazu stellt man per Browser eine HTTPS-Verbindung zu einem Server oder Gateway her. HTTPS ist in jedem Browser eingebaut und funktioniert praktisch überall. Auch durch eine Firewall oder NAT-Router hindurch. Vom Server oder Gateway lädt sich der Browser automatisch eine Java- oder ActiveX-Applikation herunter. Diese Applikation wird vom Browser ausgeführt und arbeitet als TCP/UDP-Gateway, um die VPN-Verbindungen über den Browser umzuleiten.

Dieses Verfahren funktioniert auf mobilen Geräten nur eingeschränkt, weil externe Applikationen in deren Browser nicht ausgeführt werden können.

Wie sicher ist SSL-VPN?

SSL ist für Online-Banking und eCommerce gemacht. Hier profitiert man von der Nutzung unabhängig von Ort und Software-Ausstattung. Die Kunden brauchen nur einen SSL/TLS-fähigen Browser. SSL-VPN funktioniert also von fast jedem Computer, der Internet-Zugang hat. Und das auch, bei einem unsicheren Rechner. Für manche Anwendungsfälle ist das nicht sicher genug. So unterstützt SSL/TLS keine Tunnel, was aber für ein sicheres VPN eigentlich eine Voraussetzung ist.

An der Absicherung von VPN-Verbindungen durch SSL/TLS kann man grundsätzlich nichts aussetzen, wenn man berücksichtigt, dass die Authentifizierung von SSL/TLS mangelhaft ist. Sicherer wird es, wenn man sich nicht auf das vorherrschende fehlerhafte CA-Modell verlässt, sondern selbst ausgestellte Zertifikate verwendet. Wobei man hier mit dem Aufwand der Zertifikatsverwaltung leben muss.

Außerdem muss man berücksichtigen, dass die Browser, die als VPN-Clients "missbraucht" werden unter Umständen Sicherheitslücken aufweisen oder eine fehlerhafte SSL-Implementierung enthalten.

Ein weiterer, unter Umständen kritischer Punkt, SSL verschlüsselt nur die Daten auf der Anwendungsebene, aber nicht die gesamte Kommunikation. Damit ist gemeint, dass der Aufbau der Verbindung unverschlüsselt ist, die Verschlüsselung ausgehandelt wird und erst dann die Daten verschlüsselt werden. Mit der Sicherheit, die eine IPsec-Lösung

verspricht, ist das nicht vergleichbar. Allerdings kommen in SSL viele Verschlüsselungs-, Schlüsselerzeugungs- und Hash-Verfahren zum Einsatz, die auch im IPsec- und IKE-Protokoll Anwendung finden.

Vor dem Einsatz von SSL-VPN ist also zu prüfen, ob SSL/TLS für den gewünschten Anwendungsfall sicher genug ist. Gegebenenfalls muss der SSL-Datenverkehr zusätzlich durch eine Firewall kontrolliert und die Verbindungsmöglichkeiten eingeschränkt werden.

Vergleich: IPsec und SSL-VPN

IPsec und SSL kann man nicht direkt miteinander vergleichen. Dafür ist deren Ausrichtung und Einsatzzweck zu unterschiedlich.

IPsec arbeitet infrastruktur- und anwendungstransparent auf der Netzwerkebene.

Dagegen arbeitet ein SSL-VPN ebenso infrastrukturtransparent, aber anwendungsbezogen zwischen Transport- und Anwendungsebene. In der Regel ist ein SSL-VPN schneller eingerichtet. Im laufenden Betrieb gibt es weniger Verbindungsprobleme.

Der große Vorteil von SSL-VPN ist, dass die Installation eines VPN-Client nicht zwingend notwendig ist. Es reicht ein SSL-tauglicher Browser und die Unterstützung von Java oder ActiveX. Eines von beiden sollte auf einem Standard-PC kein Problem darstellen. Insbesondere Java-Applets funktionieren Browser- und Betriebssystem-unabhängig. SSL-VPN hinterlässt auch auf dem Rechner keine Spuren. Trotzdem sind bei hohen Sicherheitsanforderungen fremde Rechner tabu. Dann sollte man kein SSL-VPN zur Verfügung stellen. Bei veralteten Browsern kann niemand wirklich eine hohe Sicherheit gewährleisten.

IPsec schützt die gesamte Verbindung und erlaubt den Zugriff nur von Geräten und Netzen, die sich dafür autorisieren. Mit IPsec lassen sich Sicherheitsrichtlinien leichter durchsetzen und Angriffsversuche besser verhindern als mit SSL-VPN. IPsec eignet sich für die Vernetzung und SSL/TLS für sichere Internet-Transaktionen.

Allerdings bietet sich SSL als Ergänzung zu IPsec an. Eine VPN-Lösung mit IPsec UND SSL, am besten mit einer einzigen Benutzerverwaltung, bietet die größtmögliche Flexibilität und kann damit jedes Einsatz-Szenario abdecken. Die Schwächen der beiden Protokolle werden in einer Gesamtlösung sehr gut ausgeglichen.

Eine IPsec-Installation durch SSL-VPN ablösen zu wollen ist in den seltensten Fällen eine gute Idee. SSL-VPN kann IPsec in der Regel nicht ersetzen, aber auf Applikationsebene mit vergleichbaren Sicherheitsfunktionen ergänzen.

VPN-Protokolle und VPN-Lösungen

Ein Protokoll legt fest, wie zwei Teilnehmer einer Verbindung miteinander kommunizieren. Bei VPN-Protokollen gibt es zusätzlich noch Methoden zur Verschlüsselung der Verbindung und gegenseitiger Authentifizierung der Teilnehmer.

Die meisten VPN-Protokolle sind in eine VPN-Lösung eingebettet. Das heißt, in Kombination mit Hardware und Software zu nutzen. Wie genau die Lösung aussieht hängt vom Hersteller ab. Parallel dazu gibt es Open-Source-Software, die sich flexibel zu einer VPN-Lösung arrangieren lässt.

Was ist ein VPN?

Eine allgemein gültige Definition für VPN gibt es nicht. Der Begriff und die Abkürzung VPN steht für Virtual Private Network und eine Vielzahl unterschiedlicher Techniken. Unter einem VPN versteht man in der Regel ein logisches privates Netzwerk auf einer öffentlich zugänglichen Infrastruktur. Nur die Kommunikationspartner, die zu diesem privaten Netzwerk gehören, können miteinander kommunizieren und Informationen und Daten austauschen.

Übersicht

- IPsec
- SSL-VPN
- WireGuard
- OpenVPN
- Layer-2-VPN

IPsec

IPsec ist eine Erweiterung des Internet-Protokolls (IP) um Verfahren zur Verschlüsselung und Authentifizierung. Damit erhält das Internet-Protokoll die Fähigkeit IP-Pakete kryptografisch gesichert über öffentliche und unsichere Netze zu transportieren.

- [IPsec - Security Architecture for IP](#)

SSL-VPN

SSL-VPN ist eine Art Remote-Access-VPN auf Basis von HTTP und TLS (SSL). Während die meisten VPN-Techniken relativ komplex und fehleranfällig sein können, kommt SSL-VPN durch jede Firewall und durch jedes Netzwerk hindurch. Außerdem hat jeder Rechner den erforderlichen Client, einen Webbrowser, installiert.

- [SSL-VPN](#)

WireGuard

WireGuard ist sowohl ein VPN-Protokoll als auch eine VPN-Software auf Basis von Open-Source zum Herstellen von Verbindungen für ein Virtual Private Network (VPN). WireGuard wurde vollständig neu implementiert und dabei auf Altlasten verzichtet.

- [WireGuard](#)

OpenVPN

OpenVPN ist eine betriebssystemübergreifende Open-Source-Software, die es für Linux, macOS, Windows und Unix gibt, mit der man VPN-Verbindungen aufbauen kann. OpenVPN nutzt unterschiedliche Standards und läuft als Software innerhalb eines Betriebssystems als Client oder Server.

- [OpenVPN](#)

Layer-2-VPN

Bei einem Layer-2-VPN wird das VPN von einem Netzbetreiber bereitgestellt. Der Netzbetreiber überträgt die Daten über sein nicht-öffentliches Netz und dessen Verbindungen. Obwohl im Hintergrund paketorientierte Übertragungstechniken arbeiten, sieht das Netz für den Kunden wie eine Standleitung aus.

Diese Lösung ist nur zur Kopplung großer Netze sinnvoll. Und auch nur dann, wenn man die Netze nicht übers öffentliche Internet, sondern über das private Netz eines Netzbetreibers verbinden will.

Schwachstellen von SSL und TLS

Wie sicher ist SSL bzw. TLS?

SSL bzw. TLS ist das Standardverfahren zum Authentifizieren von Kommunikationspartner und das Verschlüsseln des Datentransports mit Anwendungsprotokollen im Internet. Leider hat das alte SSL und auch TLS eine Reihe von Schwachstellen, die eine wirkungsvolle Authentifizierung und Verschlüsselung verhindern. Die Liste reicht von weit verbreiteten schwachen Implementierungen bis hin zu kompromittierten Zertifizierungsstellen. Das Ergebnis ist in der Regel, dass sich die Authentizität der verwendeten Zertifikate, die zur Authentifizierung von Servern verwendet werden, nicht gewährleisten lässt.

Kritische Zungen bezeichnen SSL bzw. TLS und die damit verbundenen Systeme deshalb als "grundlegend defekt".

Hinweis: Obwohl man in der Regel TLS verwendet, ist das Vorgänger-Protokoll mit der Bezeichnung SSL immer noch üblich. Häufig werden beide Bezeichnungen synonym verwendet.

Übersicht: Schwachstellen von TLS

- Certification Authority (CA) / Zertifizierungsstelle
- Zertifizierung / Zertifikatsausstellung
- Herausgeber-Zertifikate
- Schlüsselerzeugung
- Kompromittierte Zertifikate
- Validierung / Prüfung der Zertifikate
- Optionale Verschlüsselung
- Schwache Verschlüsselung
- Verschlüsselung und Integrität
- Software-Implementierung
- Heimlich nachinstallierte CA-Root-Zertifikate
- Zu hohe Komplexität für den Normalnutzer

Bei den meisten Schwachstellen geht es gar nicht so sehr darum, dass die eingesetzten Verfahren nicht funktionieren, sondern dass es Möglichkeiten gibt, dass ein Angreifer eine wirkungsvolle Authentifizierung und Verschlüsselung verhindern kann.

Schwachstelle: Certification Authority (CA) / Zertifizierungsstelle

Die Zertifikate werden von weltweit über 700 Zertifizierungsstellen bzw. Certification Authoritys (CA) ausgestellt. Die Aussteller sind Dienstleister im Internet, die Zertifikate ausstellen und auch überprüfen. Die größte Schwachstelle von TLS liegt bei den Zertifizierungsstellen.

Die Vertrauenswürdigkeit einer Certification Authority liegt im Ermessen der Software-Hersteller, die diese in ihre Listen mit aufnehmen. Als Nutzer hat man darauf meist gar keinen Einfluss, weil zum Beispiel ein typischer Browser per Default eine lange Liste "scheinbar" vertrauenswürdiger Root-CAs mitbringt.

Doch warum vertrauen Software-Hersteller CAs? Die CAs durchlaufen einen Audit-Prozess, bei dem sie auf Sicherheit und der Registrierprozess geprüft werden. Die CA muss den Hersteller davon überzeugen, dass sie vertrauenswürdig ist. Aber im Prinzip gibt es keine echte Kontrolle. Erst wenn etwas bekannt wird, verlieren die CAs das Vertrauen.

Umgekehrt kaufen viele Webhosting-Kunden ihre Zertifikate nicht direkt bei einer Zertifizierungsstelle, sondern bedienen sich bei Resellern oder den Angeboten von Hosting-Providern, die TLS-Verschlüsselung als Zusatzdienstleistung verkaufen. Das bedeutet, man hat nur bedingt Einfluss auf die Wahl der Zertifizierungsstelle.

Zertifizierungsstellen sind für bestimmte Angreifer lohnenswerte Angriffsziele und deshalb grundsätzlich einem nicht unerheblichen Risiko ausgesetzt. Wenn es einem Angreifer gelungen ist, Zugriff auf eine Zertifizierungsstelle zu bekommen, dann kann er sich beliebige Zertifikate erstellen. Und zwar für jeden Webserver.

Wenn das herauskommt, hilft nur noch, das Root-Zertifikat der Zertifizierungsstelle aus den Browsern und Betriebssystemen zu entfernen. Das stellt die nötige Sicherheit einigermaßen wieder her.

Schwachstelle: Zertifizierung / Zertifikatsausstellung

Grundsätzlich kann jede Zertifizierungsstelle Zertifikate für "jeden beliebigen Hostnamen" ausstellen. Deshalb kann es für jeden Hostnamen von unterschiedlichen Zertifizierungsstellen mehrere Zertifikate geben. Wenn eine Zertifizierungsstelle bei der Zertifikatsausstellung schlampig vorgeht, kann sich ein Angreifer ein gültiges Zertifikat für einen fremden Host ausstellen lassen.

Man kann davon ausgehen, dass es unter den Zertifizierungsstellen welche gibt, die "gültige Zertifikate für alles und jeden ausstellen". Dabei ist es egal, ob sie ihre internen Prozesse nicht im Griff haben, Geld verdienen wollen oder von einer staatlichen Stelle unter Druck gesetzt werden. Das bedeutet auch, dass CAs auf Anfrage für Regierungen oder Regierungsorganisationen Zertifikate ausstellen, die für Abhöraktionen oder Man-in-the-Middle-Aktionen verwendet werden können. Für eine Man-in-the-Middle-Aktion ist ein solches Zertifikat notwendig, um einen Zertifikatsfehler auf der Client-Seite zu vermeiden. Mit diesen Zertifikaten geben sich dann zum Beispiel Geheimdienste und

Ermittlungsbehörden als jemand anderer aus. Es gibt sogar die Möglichkeit Zweit- oder Wildcard-Zertifikate auszustellen. Die haben

Diese Zertifikate benötigt der Angreifer um im Rahmen eines Man-in-the-Middle-Angriffs, um die Verbindung zwischen Client und Server zu übernehmen und dem Client ein "gefälschtes" Zertifikat unterzuschieben. Da es gültig ist, nimmt der Client den Server als authentisiert an und akzeptiert die verschlüsselte Verbindung zum Man-in-the-Middle, der die verschlüsselten Daten entschlüsseln, mitlesen und sogar manipulieren kann.

Es gibt sogar Router, die initiierte TLS-Verbindungen übernehmen können. Für den Nutzer sieht das dann so aus, als ob er eine verschlüsselte Verbindung zum eigentlich kontaktierten Server hat. Dazwischen hängt jedoch der Router als Man-in-the-Middle, der die Daten unverschlüsselt an den Betreiber ausleitet.

Der Nutzer hat keine Möglichkeit zu prüfen, ob die CA den Zertifikate-Inhaber korrekt überprüft hat. Es gibt zwar drei verschiedene Arten von Zertifikaten, die unterschiedlich starken Prüfpflichten auferlegt sind. Leider gibt es keine Möglichkeit zu prüfen, ob diese Prüfpflichten auch tatsächlich eingehalten wurden. Das bedeutet, man muss der CA einfach vertrauen und darauf hoffen, dass das alles seine Ordnung hat.

Das bedeutet, das CA-Modell von TLS ist grundsätzlich kaputt. Warum? Weil es manipuliert und missbraucht werden kann. Für Abhörmaßnahmen, Man-in-the-Middle-Aktionen und Identitätsdiebstahl. Im Prinzip kann man einem Zertifikat, dass durch eine CA ausgestellt wurde, überhaupt nicht vertrauen.

Schwachstelle: Herausgeber-Zertifikate / Fälschbarkeit von Zertifikatsketten

Systeme zur Gefahrenabwehr in Unternehmen, beispielsweise Viren-Scanner, Einbruchserkennung und Data Loss Prevention (DLP), untersuchen den Datenverkehr auf den Inhalt. Nahezu jeder Anbieter kann das auch bei verschlüsselten Verbindungen. Damit das gelingt, erhalten diese Anbieter von den Zertifizierungsstellen Intermediate-CA-Zertifikate (Herausgeber-Zertifikate). Für eine Man-in-the-Middle-Aktion ist ein solches Zertifikat notwendig, um einen Zertifikatsfehler auf der Client-Seite zu vermeiden.

Dazu überwachen DLP-Systeme verschlüsselte Verbindungen als Man-in-the-Middle. Bei einer für Verschlüsselung initiierten Verbindung, schiebt sich das DLP als Man-in-the-Middle in die Verbindung und weist sich mit einem Intermediate-Zertifikate als der kontaktierte Server aus.

Mit einem Intermediate-CA-Zertifikat können beliebige Identitäten beglaubigt und als Man-in-the-Middle verschlüsselte Verbindungen aufgebrochen werden. Doch dabei werden erfolgreiche Spionage- und Überwachungsangriffe begünstigt.

Um dem vorzubeugen hilft unter anderem CA-Pinning.

- [CA-Pinning / Certification Authority Authorization](#)
- [CT - Certificate Transparency](#)

Schwachstelle: Schlüsselerzeugung

Bevor ein Server-Betreiber ein Zertifikat erhalten kann, muss er ein Schlüsselpaar, bestehend aus einem privaten und einem öffentlichen Schlüssel, erzeugen. Das Zertifikat erhält der Server-Betreiber dann, wenn er einen Antrag mit dem öffentlichen Schlüssel an eine Zertifizierungsstelle gestellt hat.

Nun gibt es einen zweifelhaften Service einiger Zertifizierungsstellen (Certification Authority, CA), die nicht nur das Zertifikat ausstellen, sondern auch gleich noch das Schlüsselpaar für den Kunden erzeugen. Sozusagen als Service für den Kunden. Besonders krass ist es, wenn der Kunde die Schlüssel per E-Mail zugeschickt bekommt. Einem unbedarften Kunden dürfte unter Umständen gar nicht auffallen, dass hier etwas schiefgelaufen ist. Doch dieser private Schlüssel wurde auf einem fremden Rechner erzeugt und über fremde Netze übertragen. Und damit könnte ihn irgendjemand abfangen oder aufgezeichnet haben. Unabhängig was danach mit dem privaten Schlüssel passiert, er ist jetzt nicht mehr geheim. Das Schlüsselpaar und das Zertifikat sind damit wertlos.

Grundsätzlich darf ein privater Schlüssel für die Entschlüsselung nicht einfach so übertragen werden. Und zum anderen darf das Schlüsselpaar nicht woanders erzeugt werden. Wenn bei der Erzeugung des Schlüssels dieser im Arbeitsspeicher und eventuell auf der Festplatte des fremden Rechners liegt, hat man überhaupt keinen Einfluss darauf. Woher will man wissen, dass mit diesem privaten Schlüssel kein Unfug

getrieben wird?

Eine CA, die die privaten Schlüssel für ihre Kunden erzeugt oder verwaltet, muss deutlich mehr Aufwand betreiben, um die Sicherheit der Daten zu gewährleisten, weil sie besonders attraktiv für Angreifer ist.

Deshalb gilt, ein Schlüsselpaar sollte am besten auf dem Rechner erzeugt werden, auf dem das Schlüsselpaar zum Einsatz kommen soll. Und auch nur dort darf es gespeichert sein. Alternativ kann das Schlüsselpaar auch auf dem Rechner des Administrators erzeugt werden und nach der Zertifizierung zusammen mit dem Zertifikat auf den Server übertragen werden. Allerdings nicht über das öffentliche Netz, sondern nur innerhalb des lokalen Netzwerks.

Benötigt der Kunde Hilfe bei der Schlüsselerzeugung, dann darf die Hilfe nur über eine Remote-Desktop-Verbindung erfolgen, damit der private Schlüssel auf dem Server des Kunden bleibt.

- [CA-Pinning / Certification Authority Authorization](#)
- [CT - Certificate Transparency](#)

Schwachstelle: Kompromittierte Zertifikate

Die Verschlüsselung mit Zertifikat beinhaltet zwei Schlüssel. Der öffentliche Schlüssel, der mit dem Zertifikat verbunden ist und ein dazu passender privater Schlüssel, der niemals in fremde Hände gelangen darf. Wenn dem Besitzer eines Zertifikats der private Schlüssel gestohlen wird, dann muss das Zertifikat in eine Blacklist (Sperrliste) aufgenommen werden, damit die Validierungsstelle diesen Schlüssel bei einer Abfrage als ungültig erklären kann. Dazu muss der Diebstahl vom Besitzer des Zertifikats erkannt und gemeldet werden. Wenn nicht kann ein Angreifer, der den privaten Schlüssel besitzt, die verschlüsselten Daten entschlüsseln.

Weil die Validierungsstellen unter Umständen nicht sicher zu erreichen ist, nehmen die Browserhersteller ungültig gewordene Zertifikate auch in ihre browsereigenen Blacklisten auf.

Schwachstelle: Validierung / Prüfung der Zertifikate

Wenn Verschlüsselung und damit die Authentifizierung wirklich von Bedeutung, dann muss jedes Zertifikat einzeln geprüft werden. Normal ist jedoch, dass die Prüfung der Zertifikate automatisiert und unsichtbar vom Nutzer erfolgt. Der Nutzer verwendet zwar TLS macht sich aber nicht die Mühe, die Identität des Servers, mit der eine verschlüsselte Verbindung besteht, tatsächlich zu prüfen. Nach dem Motto: Egal mit wem und wie, Hauptsache verschlüsselt.

Folgende Punkte sollten dazu führen, dass ein Zertifikat als ungültig erkannt wird und die Verbindung abgebrochen wird:

- abgelaufener Gültigkeitszeitraum
- unterschiedlicher Hostname im Zertifikat
- unterbrochene Vertrauenskette zum CA-Root-Zertifikat

Gerade beim letzten Punkt wird gefuscht. Häufig ist es so, dass ein Zertifikat als gültig akzeptiert wird, obwohl es nicht überprüft werden kann. Das heißt, manche Browser akzeptieren ein ungültiges Zertifikat auch dann, wenn sie keine Antwort von der Validierungsstelle/Zertifizierungsstelle bekommen (OCSP). Bei einer ausbleibenden Antwort wird die Verbindung aufgebaut und verschlüsselt, obwohl es überhaupt nicht sicher ist, dass man mit dem richtigen Server verbunden ist (fehlende Authentizität). In so einem Fall könnte die Verbindung durch eine Man-in-the-Middle-Aktion gesteuert werden und eine offensichtlich verschlüsselte Verbindung von einer dritten Person abgehört werden.

- [OCSP - Online Certificate Status Protocol](#)

Schwachstelle: Optionale Verschlüsselung

Generell startet jeder Verbindungsaufbau unverschlüsselt. Über diese unsichere Verbindung vereinbaren die Kommunikationspartner eine verschlüsselte Verbindung. Wenn jetzt einer der beiden Kommunikationspartner kein TLS beherrscht, dann wird die Verbindung unverschlüsselt hergestellt.

Das bedeutet, schaltet sich ein Angreifer zwischen die Kommunikationspartner und filtert den Wunsch zur Verschlüsselung heraus, dann kann er eine "unverschlüsselte Verbindung erzwingen", obwohl man den Wunsch nach einer verschlüsselten Verbindung hat.

Das Problem dabei ist, dass die Kommunikationspartner die Verschlüsselung nicht zwingend, sondern nur als Option annehmen. Konsequenterweise sollte es so sein, dass eine als verschlüsselt initiierte Verbindungsaufnahme zu einer verschlüsselten Verbindung führt oder abgebrochen wird.

Für HTTP gibt es HTTP Strict Transport Security, kurz HSTS. Darüber teilt der Webserver dem Browser mit, dass HTTP-Requests über eine verschlüsselte Verbindung erfolgen sollen.

HSTS - HTTP Strict Transport Security

Mit HTTP Strict Transport Security, kurz HSTS, teilt ein Webserver dem Browser mit, dass HTTP-Requests über eine verschlüsselte Verbindung erfolgen sollen. Nicht nur jetzt, sondern auch zukünftig. Unterstützt der Browser HSTS, dann merkt er sich das und wandelt alle unsicheren HTTP-Links in verschlüsselte HTTPS-Links um. Auf diese Weise stellt der Browser immer eine verschlüsselte HTTPS-Verbindung her. Auch wenn der Benutzer eine URL ohne "https" in die Adresszeile eingibt, findet die Umleitung automatisch auf die HTTPS-URL statt. Auf diese Weise zwingt der Server den Browser ausschließlich HTTPS-Links zu benutzen.

Der Webserver kennzeichnet im Header-Feld "Strict-Transport-Security" die HSTS-Unterstützung gekennzeichnet. So baut der Browser immer eine verschlüsselte Verbindung zum Server auf und entbindet den Nutzer vor dieser Verantwortung.

Wie sicher ist HSTS?

Prinzipiell setzt HSTS die korrekte Unterstützung sowohl beim Webserver als auch beim Browser voraus. Es verhindert, dass der Nutzer eine unsichere Verbindung aufbaut, obwohl eine verschlüsselte Verbindung möglich wäre. Doch ein Man-in-the-Middle kann die Umleitung verhindern, indem er die https-URLs durch normale http-URLs austauscht. Anschließend kann der Man-in-the-Middle alle Daten abgreifen. Helfen würde nur, dass der Webserver ausschließlich verschlüsselte HTTPS-Verbindungen akzeptiert.

Schwachstelle: Schwache Verschlüsselung

Beim TLS-Verbindungsaufbau teilt der Client dem Server eine Liste mit den unterstützten Verschlüsselungsverfahren mit. Normalerweise sollte der Server den ersten Vorschlag aus der Liste wählen, den auch er unterstützt. Hier sollte mindestens AES mit 128 Bit zum Einsatz kommen. Allerdings richten sich nicht alle Server danach, sondern bestimmen die Auswahl selber.

Oft genug werden die mit TLS verschlüsselten Verbindungen mit RC4 verschlüsselt. Obwohl RC4 aufgrund seines Alters als nicht besonders sicher gilt, wird es sehr häufig verwendet. Warum? Der Hauptgrund dürfte der geringe Bedarf an Rechenleistung beim Verschlüsseln und Entschlüsseln sein. Im Vergleich mit AES ist RC4 schneller und verbraucht weniger Rechenleistung.

Für die Betreiber vieler Server mit riesigen Datenmengen reicht die Verschlüsselung von RC4 vollkommen aus. Außerdem hat auch AES Schwächen. Es ist anfällig gegen BEAST-Angriffe, sofern die Client-Programmierer nicht vorgesorgt haben (TLS-Version 1.2).

Schwachstelle: Verschlüsselung und Integrität

Wenn jemand eine Nachricht verschicken will, die nur der Empfänger und sonst niemand lesen können soll, dann sorgt man auch dafür, dass sie nicht verändert werden kann bzw. die Veränderung beim Empfänger erkannt wird. Das bedeutet, es wird verschlüsselt und die Integrität sichergestellt. Für die Integrität wird ein sogenannter Message Authentication Code (MAC), typischerweise mit einer kryptografischen Hash-Funktion, erstellt. Dazu wird aus einem auf beiden Seiten bekannten Geheimnis ein Hash-Wert gebildet.

Nun gibt es an der Stelle die Frage, ob man zuerst verschlüsselt und dann den MAC bildet, oder ob man zuerst den MAC bildet und danach verschlüsselt. Nun ist es so, dass man festgestellt hat, dass es besser ist, wenn man zuerst verschlüsselt und dann den MAC bildet. TLS macht es aber genau andersherum. TLS erzeugt erst den MAC und verschlüsselt dann, was zu einigen Problemen und Fehlern geführt hat. Der IETF-Arbeitsgruppe von TLS ist das durchaus bekannt. Bisher ist es jedoch zu keiner Korrektur gekommen.

Schwachstelle: Software-Implementierung

Generell hängt die Sicherheit von Kryptographie und Verschlüsselung davon ab, dass zum einen die Verfahren sicher sind und zweitens die Verfahren korrekt angewendet werden. Krypto- und Verschlüsselungsalgorithmen korrekt zu benutzen ist aber nicht so ganz einfach. Dazu braucht es Hintergrundwissen und viel Erfahrung.

Um es sich einfacher zu machen nutzen viele Entwickler die unterschiedlichsten Software-Bibliotheken. Im Fall von TLS zum Beispiel JSSE, OpenSSL oder GnuTLS. Diese Bibliotheken bieten dem Programmierer eine Vielzahl von Optionen und Einstellungen, die bei einer ungünstigen Konstellation eine wirksame Verschlüsselung außer Kraft

setzen können. Wenn diese Bibliotheken fehlerhaft genutzt werden, ist die Verschlüsselung unwirksam.

Leider sind die Schnittstellen vieler Bibliotheken schlecht entwickelt und überfordern die Programmierer. Erschwerend kommt hinzu, dass es an vernünftigen Testmöglichkeiten für Programme fehlt, die TLS-Funktionen nutzen.

Das bedeutet, dass Programme und Anwendungen mit TLS-Verschlüsselung nicht zwangsläufig sicher sind. Unterschiedliche Studien haben gezeigt, dass die Überprüfung von Zertifikaten in vielen wichtigen Programmen und Bibliotheken nicht richtig funktioniert. Das öffnet Tür und Tor für Man-in-the-Middle-Angriffe. Das betrifft Online-Shops, Messaging-Dienste, Cloud-Dienste, Mobile-Apps, bis hin zu kritischen Geschäftsanwendungen, die sensible Kundendaten transportieren. Als Anwender hat man so gut wie keine Möglichkeit zu überprüfen, ob auch alles mit rechten Dingen zugeht. Hier hilft nur ein Blick in den Quellcode.

Schwachstelle: Heimlich nachinstallierte CA-Root-Zertifikate

Wer denkt, dass kommerzielle Software besser ist, der täuscht sich. Die Krypto-API von Windows zum Beispiel aktualisiert die Liste seiner Root- bzw. Stamm-Zertifikate dynamisch über einen Update-Mechanismus (nicht Windows-Update). Das heißt, kennt Windows ein Zertifikat nicht, aktualisiert es seine Liste im Hintergrund, ohne den Nutzer zu informieren. Dieser Vorgang gilt dann für das gesamte System und alle Software-Clients, die auf diese Krypto-API zurückgreifen. Dazu zählen der Internet Explorer, aber auch Chrome und Safari (nicht Firefox).

Das Problem dabei? Die heimlich nachinstallierten CA-Zertifikate. Das mag benutzerfreundlich sein. Aber ist es auch sicher? Besser wäre es, der Benutzer bekäme zumindest eine Sicherheitswarnung.

Schon jetzt kommen die Zertifikatslisten über Content Distribution Networks, beispielsweise Akamai. Denkbare wäre, dass sich Geheimdienste direkt über Microsoft oder über Umwege in den Zertifikatsspeicher als vertrauenswürdige Herausgeber importieren.

Fazit: Hohe Komplexität für den Normalnutzer

Für den Normalnutzer, der eine verschlüsselte Verbindung zu Online-Shops oder beim Online-Banking aufbaut, gibt es keine aussagekräftigen Prüfmechanismen, die notwendig wären, um einen Server vollständig zu authentisieren. Dafür sind die Vorgänge viel zu komplex und vielschichtig, als dass ein Normalnutzer fassen und beurteilen könnte.

Warum ist TLS unsicher?

Man kann TLS als sicher ansehen. Doch ist es auch sicher genug? An SSL ist das CA-Modell der entscheidende Knackpunkt. Nahezu alle beschriebenen Schwachstellen hängen sich daran auf. Sehr häufig haben Sicherheitsprobleme bei TLS mit dem CA-

Modell zu tun. Dabei ist es wichtig zu verstehen, dass nicht TLS am Arsch ist, sondern das Vertrauensmodell auf deren Basis die Authentisierung erfolgt bzw. die Authentizität der Gegenstelle sichergestellt wird. Nur wenn dieser Vorgang wasserdicht ist, kann auch die Verschlüsselung wirksam sein. Da die Authentizität der Gegenstelle bei TLS nicht zweifelsfrei sichergestellt werden, weil die CAs, die Zertifizierung und die Validierung manipulierbar sind, ist jede noch so starke TLS-Verschlüsselung als unsicher anzusehen.

Jedem Anwender, der TLS nutzt, und das tut jeder, der im Internet Verschlüsselung nutzt, muss klar sein, dass er mit einer gewissen Unsicherheit leben muss.

Was ist zu tun?

Betrachtet man die Schwachstellen von TLS stellt sich die Frage, welcher zentralen Instanz man noch vertrauen kann? Wer kann mir als Anwender versichern, dass der Server den ich kontaktiert habe, wirklich der Server ist, den ich erreichen will? Welche Alternativen zum bisherigen CA-Modell gibt es?